

Scenario 1 — LLM-Integrated Authentication Assistant System

Project Description

System Overview

The system is an LLM-integrated authentication assistant platform that provides traditional user authentication functionality together with an AI-powered assistant for authentication-related informational support.

Users interact with the system through a web frontend. The system supports user registration, login processing, credential verification, authenticated session management, and an AI chatbot for authentication-related questions.

The traditional authentication components are responsible for authentication decisions and session management. The LLM-based components provide informational assistance only.

The external LLM provider is not an authentication authority and is not trusted with authentication decisions, account modification, session management, or direct access to application databases.

No LLM-generated output is treated as an authentication or authorization decision.

System Components

External Entity — EE1: End User

The End User operates outside the application trust boundary and interacts with the system through the Web Frontend.

The user may:

submit registration information;

submit login credentials;

submit authentication-related chatbot questions;

receive registration and authentication results;

receive chatbot responses.

All user-provided data, including chatbot free-text input, must be considered untrusted input.

The user may be either a legitimate user or a malicious actor attempting to interact with the application.

External Entity — EE2: External LLM Provider

The External LLM Provider is a third-party service outside the application's security control.

It receives prompts and approved contextual information from the LLM Integration Service and returns generated responses.

The External LLM Provider:

does not authenticate users;

does not determine whether authentication succeeds;

does not modify user accounts;

does not manage application sessions;
does not directly access the User Database;
does not directly access Session Storage;
does not directly access the Knowledge Base;
operates outside the application's security trust boundary.

Generated LLM responses must be considered untrusted external output.

Internal Processes

P1 — Web Frontend Interface

The Web Frontend is the primary application entry point.

Responsibilities:

receive registration requests;
receive login requests;
receive chatbot questions;
transmit submitted data to appropriate backend services;
display authentication and registration results;
display chatbot responses.

The Web Frontend must not make authentication decisions itself.

Data received from the End User is untrusted.

P2 — Authentication Service

The Authentication Service performs traditional authentication operations.

Responsibilities:

receive registration and login data;

validate authentication input;

verify supplied credentials;

communicate with the User Database;

create or update user account information where applicable;

determine whether a login attempt succeeds or fails;

request session creation after successful authentication;

return authentication results to the Web Frontend.

Authentication decisions are made exclusively by this service and the associated traditional authentication mechanisms.

The Authentication Service does not delegate authentication decisions to the LLM.

P3 — Session Management Module

The Session Management Module manages authenticated application sessions.

Responsibilities:

create sessions after successful authentication;

generate secure session identifiers or tokens;
store session-related information;
validate session information;
maintain authentication state;
invalidate or terminate sessions where required.

Session tokens are application security credentials.

Session tokens must not be exposed to the external LLM provider or included in chatbot prompts.

P4 — AI Chatbot Component

The AI Chatbot provides informational assistance related to authentication.

Responsibilities:

receive user chatbot questions;
treat chatbot questions as untrusted input;
request approved contextual information where required;
prepare chatbot requests;
communicate with the LLM Integration Service;
receive processed LLM responses;
display chatbot responses to the user.

The AI Chatbot:

does not authenticate users;

does not determine authentication success;

does not modify user accounts;

does not create or modify sessions;

does not directly access the User Database;

does not directly access Session Storage;

does not grant privileges.

If authentication context is required for chatbot functionality, only the minimum necessary authenticated-user context should be provided; session tokens and authentication secrets must not be provided to the LLM.

P5 — LLM Integration Service

The LLM Integration Service is the controlled application interface to the external LLM provider.

Responsibilities:

receive chatbot requests;

construct prompts;

retrieve and include approved contextual information;

enforce application-level restrictions on information sent to the external LLM;

communicate with the External LLM Provider;

receive generated responses;

validate, filter, and sanitize generated responses as appropriate;

return processed responses to the AI Chatbot.

The LLM Integration Service must treat both user-supplied prompt content and externally generated LLM output as untrusted.

The service must not allow LLM output to directly execute authentication, authorization, account modification, or session-management operations.

The credential or API key used to access the External LLM Provider is server-side secret material. It must not be exposed to the End User, Web Frontend, chatbot output, prompts, or LLM-generated responses.

Data Stores

DS1 — User Database

The User Database stores authentication and account information.

Stored information includes:

usernames;

password hashes;

account information;

authentication records.

Plaintext passwords are not stored.

The User Database is accessible by the Authentication Service through controlled application interfaces.

The External LLM Provider has no direct access to this database.

DS2 — Session Storage

Session Storage contains application session information.

Stored information includes:

session identifiers;

authentication session information;

token-related data;

session state.

Session information is accessed by the Session Management Module.

The External LLM Provider has no direct access to Session Storage.

DS3 — Knowledge Base / Context Repository

The Knowledge Base contains approved information used to provide authentication-related chatbot context.

It may contain:

authentication documentation;

approved security guidance;

approved contextual information;

information required to answer authentication-related questions.

The Knowledge Base must not be treated as a source of authentication decisions.

The AI Chatbot accesses the Knowledge Base through controlled application processes.

Main Data Flows

Registration and Authentication Flow

DF1 — Registration Request

The End User sends registration information to the Web Frontend.

The information may include username, password, and required account information.

DF2 — Registration Data

The Web Frontend sends validated registration information to the Authentication Service.

DF3 — Account Creation

The Authentication Service creates or updates the corresponding account information in the User Database.

Passwords are processed using the application's password-storage mechanism and are stored as password hashes rather than plaintext passwords.

DF4 — Registration Result

The Authentication Service returns the registration result to the Web Frontend.

DF5 — Login Request

The End User submits login credentials through the Web Frontend.

DF6 — Credential Submission

The Web Frontend forwards the login credentials to the Authentication Service.

DF7 — Credential Verification Query

The Authentication Service queries the User Database to verify the supplied credentials.

DF8 — Authentication Verification Result

The User Database returns the required authentication verification information to the Authentication Service.

DF9 — Session Creation Request

After successful authentication, the Authentication Service requests creation of an authenticated session from the Session Management Module.

DF10 — Session Token

The Session Management Module returns the session identifier or token to the Web Frontend through the application.

The session token is treated as security-sensitive information and is never provided to the External LLM Provider.

Session Data Flows

SF1 — Session Persistence / Lookup

The Session Management Module creates, stores, retrieves, or validates session records using Session Storage.

SF2 — Session Record / Validation Result

Session Storage returns the relevant session information or validation result to the Session Management Module.

If the chatbot requires authenticated-user context, the Session Management Module may provide a minimal authenticated-user context or validation result to the AI Chatbot.

The actual session token must not be sent to the External LLM Provider.

AI Assistant Flow

DF11 — Chatbot Question

The End User submits a free-text authentication-related question through the Web Frontend.

The chatbot question is untrusted, attacker-controlled input.

DF12 — Prompt Request

The AI Chatbot sends the user question and only the minimum required application context to the LLM Integration Service.

Sensitive authentication credentials, session tokens, passwords, password hashes, API keys, and unrelated confidential data must not be included.

SF3 — Approved Context Query

The AI Chatbot or LLM Integration Service requests approved contextual information from the Knowledge Base.

SF4 — Approved Context Data

The Knowledge Base returns approved contextual information to the requesting application component.

DF13 — Prompt and Context Data

The LLM Integration Service constructs and sends the prompt together with approved contextual information to the External LLM Provider.

The data crossing this boundary must be limited to information permitted for disclosure to the third-party LLM service.

DF14 — Generated Response

The External LLM Provider returns generated content to the LLM Integration Service.

The generated response is untrusted external output.

DF15 — Processed Response

The LLM Integration Service validates, filters, and sanitizes the generated response as appropriate before returning it to the AI Chatbot.

DF16 — Chatbot Answer

The AI Chatbot displays the processed response to the End User through the Web Frontend.

The chatbot response is informational and does not constitute an authentication or authorization decision.

Trust Boundaries

TB1 — External User Environment / Application Environment

Separates the End User and user-controlled input from application-controlled components.

Data crossing this boundary must be treated as untrusted.

TB2 — Application Environment / External LLM Provider

Separates application-controlled components from the third-party External LLM Provider.

The External LLM Provider is outside application security control.

Data crossing this boundary must be explicitly controlled.

LLM-generated output crossing this boundary into the application must be treated as untrusted.

TB3 — Application Environment / Protected Data Layer

Separates application processes from protected application data stores, including:

User Database;

Session Storage;

Knowledge Base.

Only authorized application components may access these stores.

Security Context

The system combines traditional authentication mechanisms with an LLM-based informational assistant.

The traditional authentication and session-management components are security-critical components.

The LLM components are assistance components and are not trusted as security authorities.

The following security assumptions apply:

Authentication decisions remain exclusively under the control of the Authentication Service.

Session creation and validation remain under the control of the Session Management Module.

The External LLM Provider cannot directly access application databases.

The External LLM Provider cannot directly modify user accounts.

The External LLM Provider cannot directly create, modify, or terminate application sessions.

User-provided input is untrusted.

LLM-generated output is untrusted.

Session tokens and authentication secrets are not provided to the External LLM Provider.

Only approved contextual information may be transmitted to the External LLM Provider.

LLM-generated responses cannot directly execute privileged application operations.

Authentication and authorization decisions cannot be delegated to the LLM.

The purpose of the threat model is to identify applicable security threats affecting authentication, authorization boundaries, session management, data stores, data flows, trust boundaries, web application components, and LLM integration.

Threat Modeling Instruction

Identify all security threats applicable to the architecture and data flows described above. Do not assume that every component or security category necessarily contains a threat. Identify threats based on the actual architecture, trust boundaries, assets, data flows, component responsibilities, and stated security assumptions.

For each identified threat, determine the appropriate classification independently rather than assigning classifications merely because a framework category is available. Avoid inventing components, data stores, privileges, data flows, or capabilities that are not present in the architecture.

The External LLM Provider must be treated as an external third-party service, and its generated output must be treated as untrusted. The LLM must not be assumed to possess authentication, authorization, account-management, or session-management privileges.